Tutor Feedback

Security and Risk Management

Development Team Project: Risk Identification Report

Group: 1

---

1. **Knowledge and Understanding of the Topic/Issues Under Consideration (25%):** The report demonstrates a sound understanding of the existing operational, technological and supply-chain risks facing Pampered Pets. The discussion is appropriately connected to the circumstances of a small business, particularly the dependence on an ageing warehouse computer, shared wireless access, limited staffing, locally sourced ingredients and face-to-face sales. The use of ISO 31000, ISO/IEC 27005 and NIST SP 800-30 provides a credible foundation for the assessment. The 5×5 risk matrix is clearly explained, and the acknowledgement that the available information does not support precise probability estimates shows a sensible understanding of the limitations of the case evidence. The current-state risk table identifies relevant assets, threats, consequences and controls, rather than presenting a generic list of cybersecurity risks.

   There are, however, areas where the knowledge could be demonstrated more fully. The justification for combining ISO 31000, ISO/IEC 27005 and NIST SP 800-30 is quite brief and does not explain clearly what each framework contributes to the assessment. The current-state analysis also gives greater attention to technical risks than to physical security, staff absence, human error, business continuity, fire, theft, regulatory compliance and financial fraud. Although all six risks are relevant, the report would be stronger if it distinguished

between threats, vulnerabilities, assets and business consequences more consistently. A fuller explanation of the likelihood and impact scores would also make the risk ratings more transparent. **(Grade: 18%).**

2. **Application of Knowledge and Understanding (25%):** The risk-management principles have generally been applied well to the Pampered Pets scenario. The proposed changes, including e-commerce, hosted payments, cloud inventory, point-of-sale management and digital marketing, are realistic for the size and nature of the business. The report also recognises that international sourcing is a separate strategic decision rather than an automatic part of digitalisation. This is an important distinction. The proposed mitigations are practical and proportionate, including multifactor authentication, network separation, tested backups, hosted payment services, role-based access and a limited e-commerce launch. The phased recommendation is particularly suitable because it allows the company to improve its existing controls before taking on additional digital risks.

   The application could be developed through a more complete treatment plan. Most mitigations are expressed in only a few words and do not identify responsibility, implementation timescales, expected cost, control priority or residual risk. STRIDE is introduced appropriately, but its application is limited mainly to account spoofing and data tampering. A clearer threat model covering spoofing, tampering, repudiation, information disclosure, denial of service and privilege escalation would strengthen the digital assessment. The report could also consider website availability, insecure third-party integrations,

ransomware, fraudulent orders, returns, delivery failure, staff training requirements and dependence on technology suppliers. Including revised risk scores after mitigation would show more clearly whether the proposed controls reduce each risk to an acceptable level. **(Grade: 18%).**

3. **Criticality (25%):** Critical evaluation is one of the strongest aspects of the submission. The report does not accept the proposed figures of 50%, 24% and 33% without question. Instead, it correctly treats them as assumptions requiring evidence. The discussion of online growth recognises that market demand alone is insufficient and that the capacity of four employees may become the main constraint. Similarly, the analysis of international sourcing moves beyond the headline purchase price by considering freight, customs, currency movements, inventory requirements, quality assurance and lead times. The discussion of possible customer loss is also balanced because it recognises both the convenience of online ordering and the continuing value of personal service and local identity. These points lead logically to the recommendation for phased digitalisation and hybrid sourcing.

   Nevertheless, the analysis would benefit from further comparison between the two assessed options. The current and proposed risks are presented separately, but there is no consolidated comparison showing which risks increase, decrease, transfer to third parties or remain unchanged after digitalisation. Almost every digital risk is rated High, which limits the report's ability to establish meaningful priorities. The analysis could also examine risk appetite, financial affordability, legal exposure and possible conflicts between

cybersecurity, operational efficiency and customer convenience. The external evidence is relevant, although a wider range of academic and industry research would provide firmer support for the conclusions. Overall, the judgement is thoughtful and balanced, but the supporting analysis could be taken further. **(Grade: 20%).**

4. **Structure and Presentation (as detailed in the assessment guidance (25%):** The report is clearly organised and easy to follow. The executive summary identifies the main findings and recommendation without repeating the entire report. The movement from the current-state assessment to digitalisation risks, comparative analysis and recommendations creates a logical progression. The two risk tables allow the reader to review threats, impacts, scores, ratings and mitigations efficiently. Writing is generally concise, professional and carefully proofread. In-text citations are used appropriately, and the reference list includes credible sources such as ISO, NIST, the ICO, DSIT, the Food Standards Agency and the ONS.

   Some presentational improvements are still needed. The tables are quite dense, and additional space or slightly wider columns would improve readability. The source and reasoning behind individual risk scores could be stated more explicitly, either within the tables or immediately below them. A short contents page and numbered headings would make navigation easier, particularly for a formal consultancy report. The reference formatting is mostly consistent, but it should be checked carefully against the institution's required referencing style, especially the presentation of organisational authors,

standards, web addresses and access dates. The report could also include a brief conclusion that draws the comparative findings together before the final recommendation. **(Grade: 18%).**

Overall Grade: 74%